

GreenLeaf E-Commerce – Data Protection Impact Assessment (DPIA)

Prepared By: Cameron Naidoo, GRC Analyst | Date: 26/06/2026 | Version: 1.0

Purpose: To assess the privacy risks associated with the processing of customer personal data in the AWS cloud database.

1. SCOPE DATA INVENTORY

This DPIA covers the processing of personal data for all customers of GreenLeaf E-Commerce, the data includes:

- Name
- Email Address
- Shipping Address
- Cell Phone Number
- **Credit Card Information** (shared with PaySecure for processing)

Data flow summary:

1. **Collection** data is entered by the customer on the green leaf checkout page
2. **Transmission** data is sent securely via HTTPS to the green leaf AWS server
3. **Storage** data is stored in the AWS cloud database
4. **Sharing** payment data is shared with the third party processor, PaySecure

2. IDENTIFIED PRIVACY RISKS & MITIGATIONS

Risk ID	Risk Description	Impact on Customer	Current Controls	Recommended Mitigation
PR-01	Unauthorized Access: Weak access controls (No MFA) could allow hackers to access the database via stolen credentials. (Mapped to GR-001)	Identity theft, financial fraud, and phishing attacks.	Basic password-only authentication.	Immediately enforce MFA (A.8.5) on all admin accounts to prevent credential-based intrusions.
PR-02	Data Breach at Rest: If a hacker bypasses access controls or steals the physical hardware, the raw data is exposed.	Full-scale data exposure (name, address, credit card) leading to fraud and identity theft.	Database is stored unencrypted (plain text).	Implement Encryption at Rest (A.8.24) for the AWS database to render stolen data unreadable.

3. NECESSITY & PROPORTIONALITY (Justification for Processing)

Why does GreenLeaf need this data?

- **Name, Address, Phone:** Essential for shipping physical products and providing customer support
- **Credit Card Information:** Essential for completing financial transactions via PaySecure
- **Email Address :** Essential for sending order confirmations and delivery updates

4. CONSULATATION WITH THE DATA PROTECTION OFFICER (DPO)

GreenLeaf does not currently have a dedicated DPO due to its size. The CEO has assumed the interim responsibility for data protection until the company grows sufficiently to hire a full-time officer. This assessment has been reviewed by Legal Counsel.

5. CONCLUSION & SIGN-OFF

Overall Privacy Risk Rating: HIGH.

The lack of MFA (GR-001) and the lack of Encryption at Rest present critical vulnerabilities that expose customer data to significant risk.

Immediate Actions:

1. **Critical:** Implement Encryption at Rest on the AWS database immediately (Estimated cost: \$0 – included in the AWS service).
2. **Critical:** Enforce MFA on all admin accounts (as detailed in GR-001).

Accountable Party: CTO (Jade)

Target Completion Date: 30 Days

Signatures:

Assessed By: Cameron Naidoo, GRC Analyst | Date: 26/06/2026

Approved By: | Date: 26/06/2026